



Scry 软件功能需求分析文档

Scry 安全智能运维平台

文档版本：1.0.0

产品名称：Scry 安全智能运维平台

对应赛题：第十五届中国软件杯 A2“面向麒麟操作系统的安全智能运维 Agent 设计与实现”

目标平台：麒麟高级服务器操作系统 V11、LoongArch64

编制日期：2026-07-20

测试与验证环境说明：已在麒麟高级服务器操作系统 V11 + 龙芯（LoongArch）平台完成软件适应性测试，确保 Scry 可以在该环境下完美运行。考虑到麒麟-龙芯实体环境的持续使用成本，除适应性测试外，现阶段其他功能与性能测试主要在 macOS 开发环境及其中运行的麒麟系统虚拟机中开展；后续将在麒麟-龙芯平台补充相应测试。

1. 文档目的

本文将赛题原始要求转化为可设计、可开发、可测试、可验收的软件需求，确定 Scry 的用户、业务范围、功能边界、质量属性、数据与接口约束，并为《软件功能设计文档》《软件产品说明书》《软件功能测试报告》和《软件性能（核心指标）测试报告》提供统一基线。

需求等级定义如下：

- P0：赛题硬性要求或安全底线，缺失将导致产品不具备参赛完整性。
- P1：形成完整运维闭环所需的重要能力。
- P2：增强创新性、实用性或演示效果的扩展能力。

2. 赛题需求解读

赛题要求开发部署于操作系统的智能运维 Agent，以自然语言连接管理员与操作系统，通过 MCP 将感知与运维动作封装为工具，并重点解决大模型推理和执行的不可控问题。

赛题明确提出五项基本功能：

1. OS 环境深度感知。
2. MCP 运维插件化。
3. 安全意图二次过滤。
4. 最小权限代理执行。
5. “接收指令 - 感知环境 - 推理决策 - 安全校验 - 执行结果”的链路溯源。

赛题同时要求：采用 B/S 架构；运行于 LoongArch + 麒麟高级服务器操作系统 V11；严禁未经授权修改关键配置；具备 Prompt Injection 防护。评分重点为功能完整性 55%、创新与实用性 25%、文档与演示 20%。

3. 产品目标与范围

3.1 产品目标

Scry 应实现“可感知、会分析、能受控执行、可验证、可追溯”的智能运维闭环：

自然语言请求

- > 身份与输入安全检查
- > 指标/日志/链路/OS 实时取证
- > Agent 推理与根因分析
- > 工具和参数安全裁决
- > 审批与最小权限执行
- > 执行后验证
- > 证据、记忆和审计留存

3.2 纳入范围

- 浏览器端统一运维工作台。
- 指标、日志、链路、基础设施、消息队列、仪表盘和告警查询。
- Agent 诊断、规划和受控操作。
- MCP Server、内置工具和远程 MCP 插件。
- Prompt Injection 检测、意图分类、命令复检、审批和审计。
- scry-ops 受限账户和固定包装器。
- 证据评分、证据处置、证据约束重答和 TopoMem 运行记忆。
- Loop 自动化流程、调度、条件、并行、循环、审批、执行和验证。
- 故障模拟、准确性评测以及麒麟 V11/LoongArch64 原生部署。

3.3 不纳入范围

- 不提供无边界的通用 root Shell。
- 不允许模型直接持有系统 root、数据库管理员或 Docker Socket 权限。
- 不以模型输出替代操作系统权限、策略和审批。
- 不承诺替代数据库备份、灾难恢复、终端防护或企业身份平台。
- 不把调试故障数据当作真实生产遥测。

4. 用户角色

角色	主要目标	权限边界
系统管理员	配置组织、模型、MCP、主机、策略、Loop 和审计	可管理平台配置，但操作仍受审批和最小权限约束
运维编辑者	观测系统、诊断故障、运行授权流程、处置证据	不可修改管理员专属安全配置
只读查看者	查看遥测、告警、仪表盘和授权结果	不可执行变更或维护组织配置
安全审计人员	按用户、组织、Trace 和事件检查决策链	默认只读，不接触模型 Key、SSH 私钥等秘密明文

所有资源必须包含组织边界；角色授权由服务端执行，前端隐藏按钮不能作为唯一控制。

5. 典型业务场景

5.1 磁盘空间异常

管理员提出“帮我清理系统垃圾”。系统必须先查询磁盘指标、目录占用和近期系统错误，区分普通缓存、应用日志和数据库关键文件。删除或清理动作必须匹配预配置操作、触发审批、使用受限包装器，并在执行后重新检查磁盘使用率和关键服务状态。

5.2 僵尸进程堆积

Agent 读取进程和父子关系，结合系统日志识别未正确回收子进程的父进程。系统应优先给出修复父进程 SIGCHLD/wait 处理的建议；若需要重启，必须走服务白名单和审批，不得使用 kill -9 批量处理。

5.3 磁盘 I/O 异常

系统关联主机 I/O、应用延迟、数据库等待和 Trace 路径，识别资源瓶颈与上游传播结果，输出有证据的根因、处置顺序和恢复验证标准。

5.4 配置漂移

系统比较配置摘要、变更时间与服务异常，不得直接修改关键配置文件。修复必须通过管理员登记的工具或流程，保留审批、参数哈希、执行输出和复验结果。

5.5 提示词注入攻击

当消息、附件或工具输出要求忽略系统规则、泄露提示词、绕过审批或解码执行载荷时，系统必须拒绝请求或挂起证据，记录风险规则和 traceId，且不得将该内容作为上位指令交给模型执行。

6. 功能需求

6.1 身份、组织与权限

ID	优先级	需求	验收标准
FR-IAM-001	P0	系统应验证现有 Scry JWT，并获取用户组织和角色	无令牌返回 401；失效令牌不得访问业务接口
FR-IAM-002	P0	数据、配置、对话、证据、记忆、插件和工作流应按组织隔离	不同组织不得读取或修改彼此资源
FR-IAM-003	P0	管理接口应执行服务端角色校验	VIEWER/EDITOR 调用管理员接口返回 403

ID	优先级	需求	验收标准
FR-IAM-004	P1	秘密字段列表接口只返回“是否已配置”	API 不返回模型 Key、认证头、密码和私钥明文

6.2 OS 环境深度感知

ID	优先级	需求	验收标准
FR-OS-001	P0	系统应持续接收主机 CPU、内存、磁盘、网络和进程类遥测	基础设施页面和 Agent 可按时间范围查询
FR-OS-002	P0	系统应通过受管主机读取系统概况、磁盘、内存、失败服务、监听端口和近期错误	每项巡检对应固定命令 ID，不接收任意 Shell
FR-OS-003	P0	主机连接应校验目标、端口、用户和主机密钥指纹	未确认或发生变化的指纹不得静默信任
FR-OS-004	P1	OS 证据应能与应用日志、指标和链路共享时间窗口	根因分析可引用跨信号证据
FR-OS-005	P1	感知结果应记录来源、时间、完整性和脱敏内容	可按证据 ID 和 traceId 回溯

6.3 统一可观测

ID	优先级	需求	验收标准
FR-OBS-001	P1	系统应查询指标、日志和分布式链路	支持时间范围、过滤、聚合和有界结果
FR-OBS-002	P1	系统应展示服务请求率、错误率和延迟分位数	可从服务定位端点、Trace 和日志
FR-OBS-003	P1	系统应管理仪表盘、查询和告警	Agent 可读取告警和仪表盘作为诊断入口
FR-OBS-004	P2	系统应提供 Kafka 等消息队列健康视图	展示吞吐、积压、消费延迟和相关异常
FR-OBS-005	P0	Agent 查询工具必须只读、有界并受当前用户权限约束	禁止无限时间范围、无限返回和越权读取

6.4 自然语言 Agent 与根因分析

ID	优先级	需求	验收标准
FR-AI-001	P0	用户应能使用中文或英文自然语言提出运维请求	对话支持流式输出、停止和持久化
FR-AI-002	P1	系统应提供诊断、规划、操作三种模式	操作模式仍须经过强制安全策略和审批
FR-AI-003	P0	Agent 形成事实结论前应调用工具获取证据	输出区分事实、推断、建议和不确定性
FR-AI-004	P1	复杂任务应发布 2 至 6 步计划	前端可显示步骤状态和工具结果
FR-AI-005	P0	根因分析应区分根因信号、传播结果和无关干扰项	评测按根服务、机制、证据、处置、验证和安全评分
FR-AI-006	P1	Agent 应关联 Trace 路径和错误签名检索运行记忆	多跳词汇不一致时仍能命中根因服务记录

ID	优先级	需求	验收标准
FR-AI-007	P1	工具结果可返回受限的结构化 A2UI	未知结构回退为 JSON，不执行任意前端代码

TopoMem 受控评测基线采用 55 个独立故障和 548 份运维文档，完整方法 Root Hit@5 为 0.964、MRR@5 为 0.655；该数据作为 FR-AI-005/006 的算法能力依据，完整实验数据见《软件性能（核心指标）测试报告》。

6.5 MCP 运维插件化

ID	优先级	需求	验收标准
FR-MCP-001	P0	系统应提供符合 MCP Streamable HTTP 的 Server	支持 initialize、tools/list、tools/call
FR-MCP-002	P0	内置工具应覆盖服务、告警、仪表盘、遥测、安全、SSH、证据和记忆	工具具有结构化 Schema 和稳定 ID
FR-MCP-003	P1	管理员应能注册、启停和测试远程 MCP 服务	配置包含 URL、超时和独立认证头
FR-MCP-004	P0	外部插件不得获得用户 Scry JWT	只发送管理员单独配置的加密请求头
FR-MCP-005	P1	单个远程插件失败应被隔离	超时或连接失败不导致其他工具不可用
FR-MCP-006	P0	内置安全工具故障时不得静默放行高风险操作	系统应拒绝或停止执行并记录错误

6.6 安全护栏

ID	优先级	需求	验收标准
FR-SEC-001	P0	用户消息、附件、MCP 输出和 SSH 输出均应视为不可信数据	进入模型或证据系统前执行边界标记和检查
FR-SEC-002	P0	系统应执行 Unicode NFKC 归一化和零宽字符清理	混淆字符不能绕过注入规则
FR-SEC-003	P0	系统应识别指令覆盖、提示词泄露、安全绕过、角色混淆和编码载荷	高风险命中返回 deny 或证据 suspended
FR-SEC-004	P0	系统应分类只读、诊断、变更、提权和秘密访问意图	输出 allow、require-approval 或 deny
FR-SEC-005	P0	工具执行前应二次分析命令与参数	管道、重定向、替换、破坏性命令和任意解释器被拒绝
FR-SEC-006	P0	审批必须绑定工具、目标和参数哈希	参数变化后原审批失效
FR-SEC-007	P0	未授权情况下不得修改系统关键配置	无匹配工具、策略或审批时拒绝执行

ID	优先级	需求	验收标准
FR-SEC-008	P0	安全策略必须在服务端不可绕过	自定义 Loop 缺少安全节点时底层检查仍执行

6.7 最小权限代理执行

ID	优先级	需求	验收标准
FR-EXEC-001	P0	Agent 服务和 Query 服务应使用非 root 账户运行	systemd/container 配置可验证运行用户
FR-EXEC-002	P0	受管主机应使用固定 <code>scry-ops</code> 公钥账户	禁止 root 和密码认证
FR-EXEC-003	P0	SSH 应使用 ForceCommand，禁用 TTY、转发和隧道	无法获得交互 Shell 或执行任意命令
FR-EXEC-004	P0	只读与变更操作必须通过 root 持有的固定包装器	包装器不可由 <code>scry-ops</code> 修改
FR-EXEC-005	P0	sudoers 只允许精确包装器路径和服务白名单	未登记服务和参数返回策略拒绝
FR-EXEC-006	P1	变更完成后必须执行结果验证	保存前后状态、退出码、耗时和残余风险

6.8 推理链路、证据和审计

ID	优先级	需求	验收标准
FR-AUD-001	P0	traceId 应贯穿请求、扫描、分类、策略、审批、工具、执行和验证	可按 traceId 展示完整事件序列
FR-AUD-002	P0	审计应保存用户、组织、事件、目标、裁决、风险分和输入哈希	不保存秘密明文和完整敏感输出
FR-EVD-001	P1	每项工具结果应形成独立证据对象	包含来源、摘要、哈希、置信度、关联度和状态
FR-EVD-002	P0	命中注入规则的外部证据应自动挂起	挂起或驳回证据不得参与事实结论
FR-EVD-003	P1	用户应能采纳、驳回、挂起、恢复、选择和备注证据	每次处置进入历史与审计
FR-EVD-004	P1	用户应能基于选定证据要求重新回答	重答不得重新调用工具，关键判断引用证据 ID

6.9 运行记忆与自动化 Loop

ID	优先级	需求	验收标准
FR-MEM-001	P2	系统应保存服务画像、Runbook、故障模式、处置和验证记忆	支持组织/个人作用域、来源和状态
FR-MEM-002	P2	TopoMem 应使用运行时 Trace 导航服务拓扑并用错误签名重排	跨服务词汇差异场景优先返回根因记录

ID	优先级	需求	验收标准
FR-WF-001	P1	Loop 应支持顺序、条件、并行、while/until/foreach、审批、操作和验证	保存时执行结构、数量、深度和类型校验
FR-WF-002	P1	Loop 应支持手动、Cron 和事件触发	触发进入统一 Dispatcher 和运行历史
FR-WF-003	P0	变更型 Loop 必须包含审批和验证，且底层安全链持续生效	跳过审批或更换参数不能执行
FR-WF-004	P1	运行应支持并发配额、幂等、重试、租约和恢复	Worker 失联后不重复已完成步骤

6.10 故障模拟与评测

ID	优先级	需求	验收标准
FR-EVAL-001	P1	系统应提供健康、应用、数据库、消息、资源、OS、安全和复合故障场景	场景数据带不透明 case ID，不泄露真值
FR-EVAL-002	P1	模拟数据应覆盖 Trace、日志、指标、基础设施和消息队列	可按 case ID 隔离、生成和清理
FR-EVAL-003	P1	准确性工具应自动生成数据、调用 Agent 并评分	输出逐案例和总分，记录危险建议
FR-EVAL-004	P0	清理只能删除带调试标识的数据	不影响真实遥测和用户配置

7. 非功能性需求

ID	类别	需求与量化目标
NFR-SEC-001	安全	Prompt Injection 高风险样本必须拒绝；root、任意 Shell、管道、重定向和破坏性命令必须拒绝
NFR-REL-001	可靠性	安全组件失败时默认拒绝；服务健康端点在 20 并发、200 请求下零失败
NFR-PERF-001	性能	MCP 工具目录 P95 < 500 ms；普通 Agent 首个流事件 < 3 s（不含外部模型排队）
NFR-PERF-002	性能	本地安全裁决规则计算 P95 < 50 ms
NFR-SCALE-001	扩展	遥测查询由 ClickHouse 承担；工具结果、时间范围、循环次数和并发必须有界
NFR-COMP-001	兼容	采用 B/S 架构，目标部署为麒麟高级服务器操作系统 V11 + LoongArch64
NFR-MAINT-001	可维护	Go、Node、Frontend 均应通过类型/编译检查；配置与依赖由锁文件管理
NFR-AUD-001	可审计	每次安全决策和受控执行可按 traceId 回放，秘密字段不得进入审计明文
NFR-PRIV-001	隐私	证据写入前脱敏；输入审计以 SHA-256 为主；单项证据限制为 160 KB
NFR-USAB-001	易用	常用诊断从自然语言入口完成，危险操作必须明确展示原因、审批和验证状态

8. 数据需求

8.1 核心数据实体

- 用户上下文：userId、orgId、role、token（仅请求期）。
- Thread 与消息：标题、角色、结构化消息、创建和更新时间。
- 证据：来源、内容哈希、评分、状态、关系、操作和修订记录。
- 记忆：类型、作用域、服务、内容分块、来源、关系、拓扑边和检索运行。
- MCP 插件：名称、URL、加密认证头、超时、启用状态。
- 主机与策略：主机指纹、加密凭证、工具策略、审批需求。
- 工作流：定义、版本、触发器、并发策略、运行状态和步骤事件。
- 安全审计：traceId、事件类型、裁决、风险分、输入哈希和结构化摘要。

8.2 数据保护

模型 Key、MCP 认证头、SSH 密码和私钥必须使用主密钥加密保存。API、日志、证据、A2UI 和审计不得返回秘密明文。遥测与 Agent 配置应按组织隔离，调试数据必须具有独立标识和清理边界。

9. 外部接口需求

- Web Console 通过统一 HTTP 入口访问 Query Service 和 Agent Service。
- OpenTelemetry Collector 接收 OTLP 指标、日志和链路。
- Query Service 向 Agent 提供受当前用户 JWT 约束的查询接口。
- MCP 使用 Streamable HTTP 协议和 JSON Schema 工具参数。
- SSH 仅连接固定 `scry-ops` 账户并校验主机密钥指纹。
- PostgreSQL 保存 Agent 运行状态，WASM SQLite 保存轻量配置与审计，ClickHouse 保存遥测。

10. 约束与假设

1. 目标机须具备麒麟 V11、LoongArch64 编译工具链和可用软件源。
2. Query Service 因 CGO 依赖应在目标 LoongArch64 主机原生构建。
3. Node.js 22 需在目标架构可用，Agent 采用纯 JS/WASM 依赖避免本地原生扩展阻塞。
4. 外部大模型的可用性、排队和答案质量不完全由 Scry 控制；安全裁决不得依赖外部模型。
5. 生产受管主机必须由管理员预先安装并校验 `scry-ops`。

11. 需求验收与追踪

赛题评分点	对应需求	主要验收材料
OS 感知与 MCP	FR-OS、FR-OBS、FR-MCP	功能演示、工具调用记录、OS 巡检结果
自然语言与准确性	FR-AI、FR-EVAL	对话、准确性评测结果、证据引用
安全护栏	FR-SEC、FR-EXEC、FR-AUD	注入、危险命令、审批、审计测试
根因分析	FR-AI-005/006、FR-MEM-002	复合故障诊断、TopoMem 结果
创新与实用性	FR-EVD、FR-MEM、FR-WF	证据处置、记忆检索、Loop 闭环
平台与文档	NFR-COMP、NFR-MAINT	麒麟验收记录、五份提交文档、部署材料

需求变更必须同步更新设计、测试用例和符合性矩阵。P0 需求在提交前不得处于“未设计”状态，验证结果应与对应设计和测试用例保持一致。

12. 参考资料

1. 中国软件杯 A2 赛题页面：<https://www.cnsoftbei.com/content-15-1247-1.html>
2. docs/competition/product-functional-specification.md
3. docs/scry-technical-architecture/scry-technical-architecture.pdf
4. deploy/kylin-loong64/README.md
5. deploy/scry-ops/README.md